

ISO/IEC 27001 Management Review Guide

Purpose

Folder 10 demonstrates management review of the ISMS in accordance with Clause 9.3. The focus is on evaluating suitability, adequacy and effectiveness and making documented decisions.

Inputs

Typical inputs include changes in context and interested-party requirements, performance and objectives, audit results, nonconformities and corrective actions, monitoring results, resource adequacy, and risks/opportunities.

Outputs

Management review outputs should include decisions and actions related to improvement opportunities and any need for changes to the ISMS.

Evidence

Useful evidence includes an agenda, management information pack, KPI/KRI dashboard, minutes, decisions, action tracker and evidence of follow-up.

Auditor perspective

An auditor may verify that management review occurs at planned intervals, required inputs are covered, management participates appropriately, and outputs are recorded and followed through.

Portfolio note

The management review examples are simulated portfolio documents and are not records of an actual organization's management meeting.